



Incident report analysis

Summary	The company experienced a security event when all network services suddenly stopped responding. The cybersecurity team found the disruption was caused by a distributed denial of services (DDoS) attack through a flood of incoming ICMP packets. The team responded by blocking the attack and stopping all non-critical network services, so that critical network services could be restored.
Identify	A malicious actor or actors targeted the company with an ICMP flood attack. The entire internal network was affected. All critical network resources needed to be secured and restored to a functioning state.
Protect	The cybersecurity team implemented a new firewall rule to limit the rate of incoming ICMP packets and an IDS/IPS system to filter out some ICMP traffic based on suspicious characteristics.
Detect	The cybersecurity team configured source IP address verification on the firewall to check for spoofed IP addresses on incoming ICMP packets and implemented network monitoring software to detect abnormal traffic patterns.
Respond	For future security events, the cybersecurity team will isolate affected systems to prevent further disruption to the network. They will attempt to restore any critical systems and services that were disrupted by the event. Then, the team will analyze network logs to check for suspicious and abnormal activity. The team will also report all incidents to upper management and appropriate legal authorities, if applicable.
Recover	To recover from a DDoS attack by ICMP flooding, access to network services need to be restored to a normal functioning state. In the future, external ICMP flood attacks can be blocked at the firewall. Then, all non-critical network services

	should be stopped to reduce internal network traffic. Next, critical network services should be restored first. Finally, once the flood of ICMP packets have timed out, all non-critical network systems and services can be brought back online.
--	--

- **Reflections/Notes: Key takeaway from this incident:**
The DDoS attack exploited a simple but effective vector—unfiltered ICMP traffic. This highlights the importance of proactive network hardening, even against seemingly low-level protocols. Without rate limiting and suspicious traffic filtering in place before the attack, the team had to respond reactively, which increased downtime.
- **What worked well:**
The team’s decision to stop non-critical services while restoring critical ones was effective. It minimized disruption to essential business functions and allowed the network to recover more quickly. The addition of source IP verification and network monitoring software also improved detection capabilities for future attacks.
- **What could be improved:**
The response phase currently lacks a defined *escalation timeline* and *communication plan*. In a real attack, it’s important to notify internal stakeholders (e.g., help desk, management) and possibly external partners before isolating systems. Adding a formal notification step earlier in the response process would strengthen the plan.
- **Gaps identified in the NIST CSF application:**
 - *Detect*: The team implemented monitoring *after* the attack. Ideally, anomaly detection for ICMP floods should be pre-configured as part of continuous monitoring.
 - *Respond*: The plan doesn’t explicitly mention preserving forensic evidence (e.g., packet captures) before isolating systems. This could be critical for legal follow-up or threat intelligence sharing.
- **Potential future improvements:**
 - Implement **geo-blocking** or **threat intelligence feeds** to automatically block known malicious IPs.
 - Conduct regular **tabletop exercises** simulating DDoS attacks to test the response and recovery steps.
 - Consider using a **cloud-based DDoS mitigation service** (e.g., Cloudflare, AWS Shield) to absorb large-scale ICMP floods before they reach the internal network.
- **Connection to course concepts:**
This incident clearly demonstrates the **Protect → Detect → Respond → Recover** lifecycle in action. It also shows how a failure in one control (rate limiting) forced downstream activities (response and recovery) to be more urgent and manual. This reinforces why the NIST CSF emphasizes continuous improvement rather than a one-time fix.
- **Personal reflection:**

Working through this analysis helped me realize that even a “simple” attack like an ICMP flood requires coordination across multiple CSF categories. It’s not enough to just block the traffic—you also need to detect spoofed IPs, respond without disrupting critical services, and recover in a staged way. This case will stick with me as a practical example of defense in depth.